

RESOLUTION OF RECONSIDERATION APPEAL

Examined the reconsideration appeal filed by THE PHONE HOUSE SPAIN, S.L. (hereinafter, the appellant) against the resolution issued by the Director of the Spanish Agency for Data Protection dated December 27, 2023, and based on the following

FACTS

FIRST: On December 27, 2023, a resolution was issued by the Director of the Spanish Agency for Data Protection in file EXP202306260, by virtue of which THE PHONE HOUSE SPAIN, S.L. (TPHS) with NIF B81846206 was imposed:

- for a violation of Article 5.1.f) of the GDPR, classified under Article 83.5 of the GDPR, an administrative fine of €4,000,000 (four million euros).
- for a violation of Article 32 of the GDPR, classified under Article 83.5 of the GDPR, an administrative fine of €2,500,000.00 (two million five hundred thousand euros).

This resolution, which was notified to the appellant on December 27, 2023, was issued following the processing of the corresponding sanctioning procedure, in accordance with the provisions of Organic Law 3/2018, of December 5, on the Protection of Personal Data and the Guarantee of Digital Rights (LOPDGDD), and subsidiarily under Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations (hereinafter, LPACAP), regarding the processing of sanctioning procedures.

SECOND: As proven facts of the aforementioned sanctioning procedure, PS/00084/2023, the following was recorded:

PROVEN FACTS

FIRST: First notification of the personal data breach

On April 14, 2021, TPHS notified the AEPD of a personal data breach indicating in the attached "Security Incident Report" that it is:

(...).

(...) Currently, the extent of the incident is being investigated, and as of today, there is no evidence that personal data has been accessed.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

(...) Investigations are being conducted, as well as a forensic analysis of the attack and the attackers' mode of operation.

(...) The services of the cybersecurity company, SIA GROUP, have been contracted to analyze and manage the crisis caused by the security incident."

SECOND: Second notification of the personal data breach

On April 28, 2021, TPHS submitted a new notification expanding the information regarding the reported personal data breach, through the provision of a "Security Breach Assessment Report," dated April 28, 2021, according to which:

- "It has been evidenced that the attackers had downloaded information containing personal data during the attack.

(...) The attack compromised confidentiality (...) This process would have occurred through illegitimate exports made by the attacker from the production database of customers, former customers, suppliers, and employees of Phone House by unauthorized third parties."

(...).

THIRD: Chronology of the attack

According to the "Security Breach Assessment Report," dated April 28, 2021, provided by TPHS along with the second notification of the personal data breach submitted on April 28, 2021, the chronology of

the attack is as follows:

- Start date of the attack: March 31, 2021 (estimated): (...).
- Detection date: April 11, 2021
- Resolution date: April 21, 2021

FOURTH:

In the "Ransomware Incident Analysis Report" prepared by SIA Group, contracted after the incident by TPHS for the analysis of what occurred and dated April 21, 2021, and provided by TPHS on March 1, 2021 (Registration Number: ***REGISTRO.1), the following is stated: (...).

FIFTH: Number of affected individuals:

In the "Security Breach Assessment Report," dated April 28, 2021, TPHS indicates "Approximate number of affected individuals: 13,000,000."

SIXTH: Types of affected data:

TPHS indicates in its "Security Breach Assessment Report," dated April 28, 2021,

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

3/48

"Regarding the data affected by the confidentiality breach, four categories of affected data can be distinguished:

Employees:

- Basic identifying data: name, surname, ID number or equivalent identifying document.
- Employment details and professional contact data: Position, employee number, city, date of joining the company, and business email.

Suppliers:

- Basic identifying data: name and surname.
- Professional contact data: business email.

Clients and former clients:

- Basic identifying data: name, surname, username, ID number or equivalent identifying document.
- Contact data: phone number, postal address, email.
- Date of birth, gender, and nationality.
- Bank account number of those clients who have contracted an insurance policy.
- Information related to the products purchased or services contracted."

In the "Ransomware Incident Analysis Report" prepared by SIA Group, dated April 21, 2021, the following personal data is also added:

- Phone IMEI number.

SEVENTH:

Publication of personal data on the Deep Web by the cyber attackers:

In the "Security Breach Assessment Report," dated April 28, 2021, provided by TPHS along with the second notification of the personal data breach submitted on April 28, 2021, TPHS states: (...).

In the "Ransomware Incident Analysis Report" prepared by SIA Group, contracted after the incident by TPHS for the analysis of what occurred and dated April 21, 2021, and provided by TPHS on March 1, 2021 (Registration Number: ***REGISTRO.2), it is indicated:

(...).

EIGHTH:

The personal data published on the Deep Web by the cyber attacker(s) of TPHS clients appears in clear text.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid
sedeagpd.gob.es

4/48

NINTH: Regarding the password policy:

In the "Ransomware Incident Analysis Report" prepared by SIA Group, contracted by TPHS after the personal data breach and dated April 21, 2021, it is indicated:

(...).

The inventory of systems provided by TPHS on June 28, 2021 (Registration Number: 000007128e2100028705), regarding logical access control measures to information systems, contains the following relevant information:

(...).

In the report "Data Protection Compliance Assessment – Security Measures –," conducted by a third party (Écija) and dated January 11, 2021 (a little over two months before the incident), provided by TPHS on August 17, 2022 (Registration Number: REGAGE22e00035656325), which analyzes TPHS's obligations regarding security and organizational measures in accordance with personal data protection regulations, specifically regarding technical security measures, the following is highlighted:

(...).

TENTH: CCN-STIC-807 Guide

The CCN-STIC-807 Guide, published in March 2011 by the National Cryptologic Center (CCN), (...).

ELEVENTH: Regarding the protection of perimeter security of information systems and monitoring measures for detecting malicious behavior within the network.

In the "Ransomware Incident Analysis Report" prepared by SIA Group, dated April 21, 2021, the following is indicated:

(...).

TWELFTH: Measures adopted by TPHS after the incident:

1. In the document on "User and Password Management Procedure" (version 4.0 effective from May 3, 2021) provided by TPHS on March 11, 2022 (Registration Number: REGAGE22e00006497111), the following measures are included that were not present in the previous version 3.0 that was in effect at the time of the personal data breach (and provided by TPHS with the same registration number whose last update indicates 09/29/2020):

(...).

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

5/48

2. TPHS indicates in its "Security Gap Assessment Report," dated April 28, 2021, and submitted alongside the second breach notification filed on the same day, the following "Mitigating Measures Adopted Since the Incident":

(...).

In the same report, it indicates as "Measures in the Process of Implementation":

(...).

THIRTEENTH:

In the context of the preliminary investigation proceedings, by letter dated July 8, 2022, this Agency requested TPHS the following:

"In the DPIAs related to the processing activities 'Digital Marketing,' 'Commercial Communications,' and 'Access Control to Facilities,' a residual risk is concluded while a set of security measures is determined to reduce the identified risks. In this regard, the following is required:

i. Evidence of the implementation/execution, prior to the incident, of the measures established in said DPIAs to mitigate the risks classified as 'high' or 'very high' detected.

ii. In particular, evidence of the adoption prior to the incident of the following measures aimed at mitigating the 'very high' risk arising from mass and large-scale processing or systematic observation,

as indicated in the DPIAs themselves:

- (...)
- Implement measures of pseudonymization and anonymization for the processing of personal data.
- Implement sufficient pseudonymization and anonymization measures (k-anonymization) in the case of particularly massive data processing.
- Limit access to such information to those individuals who necessarily need to access such data.
- Transparently inform about the purposes of the processing.

By letter submitted by TPHS on August 17, 2022 (registration number: REGAGE22e00035653351), the following response was provided:

"In the report provided with this letter as Document No. 2, which contains the assessment of compliance with the GDPR and the LOPDGD from a legal-organizational perspective, the compliance with the principle of transparency was analyzed, which showed a widespread compliance with the examined issues, without prejudice to the identification of areas for improvement as reflected in the aforementioned Document.

Regarding the limitation of access to information, as indicated in document No. 1 (sections 5.1 and 6.4), PHONE HOUSE had (and continues to do so) implemented an effective user management system by roles and permissions that ensures that each employee only accesses the information necessary to perform their professional duties.

As provided in document No. 1, PHONE HOUSE had implemented in the systems that were technically and organizationally applicable, measures related to pseudonymization, anonymization, and, where applicable, blocking (section 6.16 of the document)."

Documents No. 1 and No. 2 referred to by TPHS are, respectively, the reports "Assessment of Compliance in Data Protection – Security Measures –," conducted by a third party (Écija), submitted by TPHS on August 17, 2022 (Registration Number: REGAGE22e00035656325) and "Assessment of Compliance in Data Protection - Legal-Organizational Aspects –" dated January 11, 2021, and submitted by TPHS on August 17, 2022 (Registration Number: REGAGE22e00035663361).

FOURTEENTH: Data Protection Impact Assessments: Risk Assessment

In the DPIAs conducted by TPHS regarding the processing activities affected by the personal data breach ("Marketing," "Commercial Communications," "Access Control to Facilities"), dated 2018 and submitted by TPHS on June 28, 2022 (registration number: O00007128e2100028701), a description of the following "threats" is made, the "risk" is assessed, and the "measures" to mitigate those risks are indicated (by way of example and without limitation):

Regarding the processing activity "Commercial Communications":

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es

7/48

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es

8/48

Regarding the processing activity "Digital Marketing":

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es

9/48

SIXTEENTH: Processing of personal data that includes profiling

In the document containing the Record of Processing Activities and risk analysis, submitted by TPHS

on June 28, 2022 (registration number: ***REGISTRO.3), it is indicated:

Regarding the activity "Digital Marketing":

- "Large-scale processing: YES
- Scoring/profiling: YES"

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

10/48

Regarding the processing activity "Commercial communications":

- "Large-scale processing: YES
- Scoring/profiling: YES"

In the Register of Processing Activities, provided by TPHS on September 15, 2023 (Registration number: REGAGE23e00062166595), in response to the request made by this Agency during the evidence gathering procedure, it is indicated

Regarding the processing activity "Profile creation":

"- Purposes of the processing: Profile creation in order to carry out personalized advertising.

- Category of data: (i) Identifying data: Name and surname; (ii) Contact data: email, postal address, and phone; (iii) Data about contracted services or products: service or product; (iv) Data obtained through user-generated content: comments, private messages or chat, or other virtual elements.
- Category of data subjects: i) Clients; (ii) Potential clients; (iii) Web users"

SEVENTEENTH: Training courses

1. In response to a request for information from this Agency, TPHS submitted, on August 17, 2022, (Registration number: REGAGE22e00035653351) a document stating:

"PHONE HOUSE has a training plan whose main objective is to keep the knowledge of its employees duly updated, assisting them in the development of new skills and the improvement of existing ones. In the area of data protection, various courses and training sessions have been provided that cover both a general approach to the subject and the development of more specific issues that have been identified in the Company as particularly relevant, due to the impact they have on its employees and clients.

In this regard, PHONE HOUSE provided courses focused on information security and data protection, both prior to the full application of the GDPR and at the time of its adaptation to the then new European regulation in 2018. Document No. 3 is attached, listing the attendees of the training sessions and the details thereof.

Document No. 4 is attached, which includes evaluations and test-type knowledge assessments that employees must complete after receiving training in data protection when joining the Company. Additionally, PHONE HOUSE has an Information Security Policy, which is attached as Document No. 5."

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

11/48

Attached to the previous document is the following documentation (Registration number: REGAGE22e00035656325):

- Document 3. "Training Program PROG-294. Name of the program: European Data Protection Regulation"

It is a list of participants in two courses on the "European Data Protection Regulation" held between May 2018 and December 2020. In the first course, there are 388 enrolled. In the second, there are 254 enrolled.

- Document 4. Contains test-type questions

- Document 5. Information Security Policy, version 2, March 2022.

2. TPHS, in its written allegations to the Initiation Agreement, submitted on March 29, 2023, on September 15, 2023 (Registration number: ***REGISTRO.4), states:

"1) In 2015, prior to the entry into force of the GDPR, PHONE HOUSE employees received in-person training at their offices from A.A.A., a university professor and partner at the law firm A.A.A. Document No. 4 is attached, containing the content of the training and documents used by Mr. A.A.A. in 2015.

2) Between 2015 and 2016, PHONE HOUSE employees completed a training course on data protection through the E-learning platform. The screenshot attached below shows that on November 17, 2015, an email was sent to employees indicating that they needed to complete the data protection training.

6) In 2017, PHONE HOUSE launched a new course on its online platform for all its employees, the content of which is attached as Document No. 5.

2) In 2018, when the GDPR became fully applicable, the law firm ECIJA conducted several in-person training sessions at PHONE HOUSE offices. Document No. 6 is attached, containing the content of the course delivered in 2018 by ECIJA.

3) Additionally, starting from May 24, 2018, all PHONE HOUSE employees were required to complete the online course on data protection and information security available on the online platform Dominion University: <https://iseazy.com/dl/ff8e1eff94d54d4885fb82698c0a4fbc>. This course was also completed by all employees hired after 2018 upon joining the Company.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

12/48

4) Between April 7, 2020, and August 30, 2020, a new training course was activated for those workers who were going to manage Liberty insurance, in which PHONE HOUSE acts as a mediator. Below is a screenshot to evidence that the aforementioned course was available for the workers managing insurance on the PHONE HOUSE Intranet:

5) In 2021, adhering to the principle of accountability, which characterizes PHONE HOUSE's actions at all times, the content of the course that all workers were required to complete was updated to the following: ***URL.1.

6) In 2022, the course content on data protection and information security was updated again, including at the end of the training a multiple-choice exam that all workers must complete upon finishing the course. Below is a screenshot evidencing that the course is available on the PHONE HOUSE intranet.

Along with the written allegations to the Initiation Agreement, submitted on March 29, 2023, TPHS provides the following documents related to the courses mentioned above:

"Document No. 4: Content of the training and documents used by A.A.A. in 2015.

Document No. 5: Content of the training offered by PHONE HOUSE to its workers in 2017.

Document No. 6: Content of the training provided in 2018.

Documents No. 7, 8, 9, and 10: Some of the lists of training conducted by workers on data protection."

EIGHTEENTH: According to the information obtained from the Axesor service (see Diligence References), TPHS has 1,411 employees in the fiscal year 2020.

FIFTEENTH:

Data Protection Impact Assessments: Measures.

In the DPIAs conducted by TPHS regarding the processing activities affected by the personal data breach ("Marketing," "Commercial communications," "Access control to facilities"), dated 2018, two years prior to the personal data breach, and provided by TPHS on June 28, 2022 (registration number: 000007128e2100028701), risks classified as "high" or "very high" were identified, and consequently, a series of measures were determined to mitigate those risks.

Among them, the following are noted:

(...).

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es

13/48

SIXTEENTH:

In the Report “Assessment of compliance in data protection – Security Measures –,” dated January 11, 2021, the following is stated:

(...).

SEVENTEENTH: Record of Processing Activities

In the Record of Processing Activities of TPHS, provided by it on September 15, 2023, in response to the request made by this Agency during the evidence gathering process, the processing activity “Profile creation” appears, regarding which it is indicated:

“-Purposes of the processing: Profile creation in order to carry out personalized advertising.

-Category of data: (i) Identifying data: Name and surname; (ii) Contact data: email, postal address, and phone; (iii) Data on contracted services or products: service or product; (iv) Data obtained through user-generated content: comments, private messages, or chat or other virtual elements.

-Category of data subjects: i) Clients; (ii) Potential clients; (iii) Web users.”

THIRD: The appellant submitted on January 29, 2024, to this Spanish Agency for Data Protection, a request for reconsideration, fundamentally based on the following allegations:

FIRST - ON THE LACK OF MOTIVATION OF THE RESOLUTION PROPOSAL

The appellant considers that the resolution issued by the AEPD is not properly motivated and that it has evaded responding to allegations such as those related to the coincidence of the appropriate technical and organizational measures required by Articles 5.1 f) and 32 of the GDPR. In this regard, it understands that the consideration of distinct obligations has not been adequately justified. The appellant believes that the contested resolution does not meet the motivation requirement for administrative resolutions required by both the Supreme Court jurisprudence and the Constitutional Court.

SECOND - VICTIM STATUS OF PHONE HOUSE

The appellant understands that the resolution of the sanctioning file must take into account the criminal origin of the facts. And that, due to the characteristics of the cyberattack of which it was a victim, there were no means to prevent or reverse it, despite the security measures adopted.

It considers that during the processing of the sanctioning file, allegations were made to demonstrate the investments made in security services before and after the personal data breach. Furthermore,

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

14/48

considers incorrect the mention made in the contested resolution regarding the effects of the breach on the right to personal data protection of the affected parties, as it understands that this security is widely taken into account by the appellant, who must also be considered a victim and, therefore, affected by the breach that occurred.

THIRD. – ON THE ALLEGED NON-COMPLIANCE WITH ARTICLE 5.1.F) GDPR

At this point, the appellant refers to the allegations already made in this regard during the processing of the sanctioning procedure and insists that it acted diligently at all times, with adequate and reasonable security measures in light of the risk associated with the data processing carried out and in the information systems affected by the breach.

It recalls previous files processed by the AEPD, concluded with the filing of the procedure, which, in its opinion, refer to similar facts for which a sanction has been imposed on the appellant. In its view, the information from the files indicated and taken into account by the AEPD to deny the lack of criteria is incomplete.

It also claims that in all the referenced files it was positively considered that the entities victimized by cyberattacks had procedures for detecting and managing breaches, a circumstance that has not been valued as a mitigating factor in the procedure affecting them. It also points out that the measures for which it has been sanctioned in the contested resolution were not applied by the entities whose procedures were archived. It cites examples of measures such as pseudonymization or encryption of the database.

It understands, ultimately, that it has been given a discordant and discriminatory treatment.

FOURTH. - ON THE ALLEGED NON-COMPLIANCE WITH ART. 32 GDPR

Again, the appellant refers to what has already been alleged during the processing of the sanctioning procedure.

It considers that the issues that have been taken into account for the verification of the infringement are minor deficiencies, recommendations, or shortcomings whose relevance for the overall security of personal data has not been proven, beyond their relation to the final outcome of the breach that occurred as a result of an exceptionally and unusually sophisticated attack.

It highlights that the Report issued by SIA and submitted by the appellant during the procedure did not intend to assess the level of security of the systems, but rather to identify what happened and how the attack occurred. And it recalls the document submitted with the allegations to the resolution proposal titled "Clarifying Annex to the Incident Analysis Report of Ransomware," which evaluates the security measures implemented prior to the incident, and concludes that: "the protection measures by PHONE HOUSE were adequate, relevant, and proportionate, according to the state of the art" and that under no circumstances, none

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

15/48

of the measures that would have been adopted, could have prevented the brutal attack suffered by PHONE HOUSE.

This conclusion understands that it has not been undermined by any better criterion and allows it to point out that the AEPD has made a free interpretation of the content of said report that has allowed it to reach opposing conclusions.

The appellant rejects the argument contained in the contested resolution to refute the conclusions reached by said clarifying report: that it does not reflect facts but rather assessments of facts or circumstances and that its value as evidence is that which would correspond to a party report.

In the appellant's opinion, these arguments are not valid because the initial SIA report, which the AEPD did take into consideration, not only contained objective facts, since a technical report that constituted a mere narration of facts without a subsequent technical value judgment would be meaningless. In fact, it considers that these assumptions and value judgments are used by the AEPD itself when arguing the definitions of the security measures attributed to the appellant. It also understands that both reports were requested by the appellant and submitted by it to the file; both are party reports without this affecting their validity, especially when both are perfectly substantiated and when there are no other contrasting reports that have been provided by the AEPD.

Furthermore, contrary to what the AEPD understands, the new report, Annex SIA, does expressly refute the conclusions of the AEPD, according to the technical criterion of its author, a computer expert who has had the opportunity to analyze the evidence and the digital environment in which it was obtained, and whose professional background allows him to opine in a qualified manner on the adequacy of the security measures adopted.

The appellant emphasizes that the existence of points for improvement or weaknesses in the security of a system cannot be equated with an inadequacy of measures, as everything is susceptible to improvement; on the contrary, weaknesses or deficiencies must be put into context in order to determine whether they cause the system to be insecure. And, even if it is, it cannot be deduced that there is necessarily a lack of diligence.

It also points out that the conclusion of inadequacy of the measures has as its only support the result

of the cyberattack, without any technical criterion supporting such an assertion, beyond specific deficiencies whose relevance to security has not been contrasted. Furthermore, it indicates that no causal link is established between the absence of measures and the success of the attack.

Next, the appellant outlines the points of analysis corresponding to the supposed deficiencies detected:

- Regarding the Privacy Impact Assessments.

In the appellant's opinion, the high-risk treatments on which an impact assessment was carried out are clearly delineated, so it is not appropriate to extend the recommended measures in said impact assessments to other...

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

16/48

treatments that, although they may be related, are clearly differentiated in the activity register.

It understands that, although the general processing of customer data is massive, this does not make the measures proposed specifically for other treatments applicable, even if they share this characteristic. From this, it concludes that one cannot speak of the implementation of anonymization/pseudonymization or encryption measures for the general customer database, nor can one speak generically of measures recommended in impact assessments, since each contains its specific recommendations, which are not interchangeable among themselves, nor with other treatments.

It considers that the reality of the facts is being confused and non-compliances are being attributed that do not correspond with the reality established in the instruction by extending a recommendation made for a treatment different from the general customer database, with the sole objective of subsequently attributing the fact that the proposed measures were not complied with.

It again mentions the reference to the concluded precedents that also involved massive data processing and that were not encrypted.

- Regarding passwords

The appellant again points out the validity of the clarifications made in the Clarifying Annex SIA, with which it considers that the IT expert completes his report concluding on the adequacy of the measures implemented, a matter on which he had not initially been asked to express an opinion.

It considers that the AEPD's analysis of the inventory of systems provided by the appellant is incorrect, as the alleged deficiencies detected do not take into account the identification codes of the different levels of security required, according to the risk level of the systems derived from the data processing carried out within them. In this regard, all systems are classified as secure or highly secure.

Furthermore, it understands that the fact that some systems do not have measures does not mean that they do not exist, especially regarding passwords. In this sense, when there is a main validation system through the active directory, as is the case, this is the one that controls the minimum conditions of the passwords, regardless of whether the specific application to which access is granted through the active directory does not contemplate them.

The appellant also refers to the evaluation report of technical measures prepared by XXXXX, which does specifically refer to the systems in which personal data is processed, analyzing the access control system to the systems and concluding with the compliance of the obligations that pertain to it. It considers that in the case of the text extracted from the report regarding user review deadlines, it refers to a matter related to the approved internal procedure that is not residually complied with in some applications, without this implying that a significant risk is generated. And that

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

17/48

Regarding the use of the MD5 algorithm, the report states that it is not “fully secure,” a quality that cannot be claimed for almost any encryption mechanism, although this does not imply that it is commonly vulnerable, considering that it is a 128-bit algorithm. In fact, the CCN-STIC-807 Guide, to which the AEPD refers, indicates that “some weaknesses” have been found.

Finally, it considers that the fact that the password policy has been updated cannot be interpreted as justification for any prior deficiencies. The procedure refers to minimum measures, which does not imply that superior measures cannot be adopted or that they were not implemented prior to their inclusion in the policy.

- On perimeter security

In addition to the previous considerations regarding the lack of attention to the conclusions included in the Clarifying Report provided by the appellant and the incorrectness of considering that the adoption of measures after the attack reinforces the view of the measures as inadequate, the appellant insists that many of the measures implemented after the attack are well above those recommended for a scenario of similar risks and go far beyond the required diligence.

At this point, it also notes that it should be taken into account that the attackers managed to obtain credentials from a system administrator, whereby the findings identified in the SIA Report correspond to a manipulated environment and that many of the deficiencies found in perimeter security may stem from alterations made by the intruder, who had the capacity to modify the system configuration previously established by the appellant.

- On training actions

In addition to the allegations already made during the processing of the file, the appellant questions the consideration that the training and awareness courses provided to its employees constituted a violation of data protection regulations and criticizes the lack of substantiation. On the contrary, it believes that it has a robust, comprehensive, and ongoing continuous training plan in data protection and information security, and that its employees received training and awareness on data protection.

- Other measures

The appellant argues that the validity of the DPO's annual report cannot be questioned due to its date of issuance, as it must, by its nature, be conducted at the conclusion of the analyzed year. Regarding the lack of evidence contained in it, it recalls that it is not an audit report but an annual activity report, in line with what the AEPD indicated regarding the content of the DPO's annual report.

FIFTH. - ON THE EXISTENCE OF A COMPETITION OF OFFENSES

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

18/48

The appellant insists on what has already been alleged throughout the sanctioning procedure, understanding that the circumstances exist to consider that there is a medial concurrence between the alleged infringements of Article 5.1.f) GDPR and Article 32 GDPR, as the absence of appropriate technical and organizational measures is necessary for a confidentiality breach to be sanctionable. They argue that it is not possible to consider Article 5.1.f) breached when the entity had appropriate technical and organizational measures in place, thus a breach of this provision always requires a breach of Article 32 of the GDPR.

They reiterate that they do not share the AEPD's assessment that the measures referred to in Article 32 GDPR are only security measures, while those of Article 5.1.f) GDPR would also cover other types of measures, and insist that they have not received a reasoned response justifying this argument.

In the appellant's opinion, the reference to Article 83.3 GDPR in the case of concurrent infringements is not in accordance with what is established in Guidelines 04/2022, which they understand to mean that "in the case of concurrent infringements, the amount of the fine must be calculated solely on the basis of the infringement selected according to the previous rules (prevailing infringement)."; with the case of unit of action being regulated in Article 83.3 GDPR.

The appellant argues that it must be concluded that there is a concurrence of infringements, and consequently, the amount of the fine must be calculated solely based on the prevailing infringement.

SIXTH. - ON THE INADMISSIBILITY OF OBJECTIVE LIABILITY

The appellant alleges that the contested resolution is based on the concurrence of the result – the breach perpetrated by the attackers – to consider a lack of diligence on their part as proven. They believe that an objective liability is imposed, in which, regardless of the measures deployed, reference is made to the possibility of implementing more restrictive measures. They insist that the failure to implement a certain measure – especially one as restrictive as this – which is not required by any norm, standard, or binding criterion, cannot determine the imposition of sanctioning consequences. They reiterate that the data subject to high-risk processing, for which additional measures are recommended, are not those affected by the breach; hence, it cannot be argued that there was a lack of diligence in this regard.

They believe that no culpable conduct has been proven in the implementation of measures prior to the breach, nor any culpable action that would allow preventing the result, thus there is a lack of causal link.

They also reject that the entry into force of the GDPR implies an extension of liability or modifications in the requirements for sanctioning the conduct of the legal entity. An extensive interpretation rejected by the Court of Justice of the European Union in Judgments related to cases C-683/21 and C-807/21. C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

19/48

SEVENTH. - ON THE NEED TO ESTABLISH A CULPABLE INFRINGEMENT FOR THE IMPOSITION OF A FINE

Based on the jurisprudence of the CJEU mentioned in the previous section, the appellant understands that the conditions that must necessarily be met for the imposition of an administrative sanction must materialize in a culpable or deliberate act or omission by the data controller.

They consider that such culpable, intentional, or negligent conduct cannot be attributed to the appellant, who should rather be considered a victim of a cyberattack.

EIGHTH. - ON THE 211 COMPLAINTS RELATED TO THE SECURITY BREACH

The appellant relates the expiration of the investigative actions initiated on April 20, 2021, with the 211 complaints that were filed by those affected by the breach and for which no information has been provided to them.

They question that the need to continue investigating is not understood when the request for more evidence is not made until three months after the notification of the opening of new actions.

They believe that the duration of the actions constitutes a guarantee of the sanctioning procedure and that its extension must be adequately justified. In their opinion, by stating that these 211 complaints have not been processed individually, the AEPD understands that the notification that must be made to them is their inadmissibility for processing, not the resolution of the sanctioning procedure that affects the appellant. The fact that this has not been done demonstrates that those complaints have indeed been taken into account in the sanctioning procedure that has affected them and that, therefore, they should have been provided to them.

NINTH. - ON THE EVIDENCE

They consider that the assessment of the evidence has been partial and differentiated and reiterate that the statements in the Clarifying Report SIA have not been taken into account, a circumstance that has caused them defenselessness.

TENTH. - ON THE ABSENCE OF PROPORTIONALITY IN THE DETERMINATION OF THE AMOUNT OF THE PROPOSED SANCTION

Subsidiarily, the appellant raises the lack of proportionality of the imposed sanction. They question that there is no express mention of the specific factual elements in which the AEPD identifies a lack of diligence on the part of the appellant, beyond the generic mention of the possibility of implementing additional measures to those already established and implemented at the time of the attack. They argue, on the other hand, that the imposed sanction does not constitute a deterrent or confidential

element.

(...).

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

20/48

The appellant questions that, for the imposition of the fine, the number of possible affected individuals was taken into account, but without the figure of 13 million affected individuals—which corresponds to the users and clients of the appellant—being the number of interested parties whose data has been affected.

TENTH. - AGGRAVATING FACTORS ASSOCIATED BY THE AEPD TO THE INFRINGEMENTS

The appellant reiterates its allegations regarding the applicability of the aggravating factors made in the sanctioning resolution.

- 1) Nature and severity of the infringement (Article 83.2 a) GDPR). However, reference is made to "millions" or "approximate number of affected individuals," without even specifying the number of affected individuals.
- 2) Level of damages and losses suffered. It considers that no evidence is provided to substantiate the publication of the data affected by the breach on the Deep web. Therefore, this is an aggravating factor based on unproven factual elements.
- 3) Duration of the infringement. It reiterates that the systems used in high-risk processing activities that underwent an impact assessment were not affected by the breach. It understands that to appreciate the aggravating factor of duration, it would be necessary to specifically identify the measures whose prolonged and maintained absence over time determines both the commission of the infringement and an increase in its severity.
- 4) Intentionality or negligence in the infringement. It considers that the culpability required to apply this aggravating factor is not present, as the appellant is a victim of and harmed by the attack.
- 5) Linkage of the infringer's activity with the processing of personal data. It highlights that the Guidelines 04/2022 on the calculation of administrative fines exclude the specific activity and business sector of the infringer as a criterion to be considered in the imposition and quantification of sanctions arising from a breach of data protection regulations. It understands that Article 83.2 k) of the GDPR requires that this aggravating factor be related to the specific case, and since the processing of data occurs in the commission of a crime of which the appellant is a harmed party, this aspect cannot be interpreted as an aggravating factor.

ELEVENTH. - ON THE CONCURRENCE OF MITIGATING FACTORS NOT CONSIDERED

It reiterates the previous allegations regarding the application of mitigating factors to the sanctioned conduct, especially the fact that it acted diligently in managing the breach and adopted the necessary measures to mitigate the effects of the breach and reinforce the security of its systems. A mitigating factor that was already considered in a previous case of a similar nature.

TWELFTH. - ON THE ADOPTION OF MEASURES

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

21/48

Regarding the measures imposed in the contested resolution, the appellant insists that the data processing it was conducting was already compliant with data protection regulations at the time the cyberattack occurred. It also includes as an annex the additional measures that have been adopted. The appellant also attaches the list of employees who received training in data protection in 2023, along with an explanatory video of the origin of the list, as well as the updated number of employees of the Company.

LEGAL GROUNDS

I

Competence

The Director of the Spanish Agency for Data Protection is competent to resolve this appeal, in accordance with the provisions of Article 123 of Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations (hereinafter, LPACAP) and Article 48.1 of Organic Law 3/2018, of December 5, on Personal Data Protection and the Guarantee of Digital Rights (hereinafter, LOPDGDD).

II

Response to the allegations presented

In relation to the statements made by the appellant, it should first be noted that they essentially represent a reiteration of the allegations already presented throughout the sanctioning procedure, as the appellant itself states when presenting them again in the appeal. Consequently, it should be pointed out that all of them have already been analyzed and dismissed in the contested Resolution, in the following terms:

Regarding the first of the allegations, that is, the lack of motivation of the resolution proposal, it should be noted that this was addressed on pages 160 to 162 of the contested resolution, to whose terms, and in the interest of procedural economy, we refer. However, it is worth recalling that, as we indicated: Furthermore, it is appropriate to recall the recent Judgment of October 9, 2023, of the National Court, Administrative Litigation Chamber, Section 1, Rec. 1710/2021, which states the following:

“As for the annulment of the Resolution due to deficient and defective motivation, it should be noted that the requirement for motivation of administrative acts is generally imposed by Article 35 of Law 39/2015, of October 1; the motivation responds to a threefold necessity since, on the one hand, it expresses that the Administration, when interpreting the will of the norm, has acted in a reasonable manner; secondly, the recipients of the act can know those reasons and, eventually, subject them to criticism and, for...

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

22/48

Lastly, it allows for oversight by the contentious courts regarding the appeals against the contested act or provision, within the scope provided in Article 106.1 of the Spanish Constitution (CE), thus adequately satisfying the right to judicial protection proclaimed in Article 24.1 CE.

From this triple perspective, the motivation of an act or provision must be related to the specific claim made in the process and to the grounds for appeal put forward by the party, as the act can only be annulled for this reason when the lack of knowledge on the part of the appellant regarding the reasons why the Administration has acted as it has prevented them from articulating their means of defense and presenting their claim accordingly, so that only when the ignorance of those reasons has materially caused defenselessness, prohibited by Article 24.2 CE, would it be appropriate to annul the contested act.

As the Supreme Court recalled in its ruling of September 20, 2012: “[...] the requirement of motivation for administrative acts constitutes a constant in our legal system, as proclaimed by Article 54 of the LRJPA (formerly, Article 43 of the Administrative Procedure Act of July 17, 1958), with the aim of allowing the interested party to know the reasons leading to the Administration's resolution, in order, if applicable, to be able to refute them in the procedural manner regulated for that purpose. Motivation, which in turn is a consequence of the principles of legal certainty and prohibition of arbitrariness stated in paragraph 3 of Article 9 of the Spanish Constitution (CE) and which can also, from another perspective, be considered a constitutional requirement imposed not only by Article 24.2 CE but also by Article 103 (principle of legality in administrative action).” (the underlining is ours)

Therefore, the Proposal for Resolution, by containing a reasoned motivation (let us remember that the Law only requires it succinctly) for each and every one of the aspects required by the LPACAP, has

allowed TPHS to know the facts considered proven and their exact legal qualification, the infringement that, in their case, those constitute, and the sanction that has been proposed, as well as the assessment of the evidence presented, thereby allowing TPHS to formulate the allegations and provide the documents they deemed pertinent for the defense of their rights and interests.

It must therefore be concluded that the appellant has been able to exercise their right to defense throughout the processing of the sanctioning procedure, being aware at all times of the facts attributed to them and the infringements derived from them, without the rejection by this AEPD of the arguments repeatedly put forward, based on duly reasoned considerations, being interpreted as a lack of effort to understand what has been presented, as alleged by the appellant.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

23/48

Regarding the factual coincidence of the alleged infringements, since it constitutes the core of the allegation concerning the existence of a concurrence of infringements, we refer to the response to this allegation that we provide in subsequent sections of this claim.

For all the reasons indicated, this allegation must be dismissed.

The appellant reiterates that the analysis of the facts subject to the sanctioning file must start from its consideration as an affected party and victim of the cyberattack that led to the personal data breach for which it is sanctioned. This is an argument that the appellant has been putting forward since the allegations to the initiation agreement adopted on 27/03/2023 and has reiterated in all procedural phases. An argument that, on the other hand, has been justifiably rejected by this AEPD in the contested resolution: on pages 69 to 71 in response to the allegations against the initiation agreement and on pages 162 to 167 in response to the allegations against the proposed resolution. While we refer to what has been stated, it is worth recalling some of the reasoning provided:

In this regard, it is appropriate to refer to what has already been addressed on this issue in the Proposed Resolution, which is reproduced in the Ninth Background Fact, First Section. Thus, it was indicated that in no case has total infallibility of the measures that can be adopted to ensure adequate protection in the processing of personal data been required.

However, once the attack has occurred, the diligence of the data controller in implementing the appropriate technical and organizational measures to ensure a level of security appropriate to the risk must be evaluated, taking into account the state of the art, the costs of implementation, the nature, scope, context, and purposes of the processing.

In the present case, it has already been pointed out that TPHS did not have, at the time of the personal data protection breach, the appropriate measures concerning the risks of processing for the protection of personal data, as indicated in the Initiation Agreement of the present sanctioning procedure, and which is again referenced in the Legal Basis VII of this Resolution and to which we must refer, there were deficiencies regarding:

- 1.- the password policy and other restrictions for access to TPHS's information systems.
- 2.- the protection of perimeter security and monitoring measures for the detection of malicious behavior;
- 3.- the training and awareness of employees.

Furthermore, it did not have the security measures that, regarding the treatments affected by the breach, it had indicated in its own DPIAs that should be implemented, in view of the high and very high risks identified (pseudonymization, encryption, anonymization...). Therefore, the security measures were not adequate to the risks, as required by Article 32 of the GDPR, regardless of the specific attack suffered.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

24/48

The appellant reiterates the investments made prior to the breach and also subsequent to it. Without prejudice to our reaffirmation of the argument that the subsequent expenses arising from the attack cannot be understood as a reflection of the diligence of the Data Protection Officer (DPO) before the breach occurred, quite the opposite, since many of the measures implemented afterward should have been in place beforehand to ensure adequate security based on the risk, it should be noted that, regarding the prior investment recalled by the appellant, the technical and organizational security measures must not only be adequate but must also be implemented and used with reasonable diligence.

Furthermore, we consider that, with the mention of the amount of investment made, it not only does not justify that the measures were adequate, but also does not demonstrate that they were properly implemented and, above all, that they were effective in addressing the risks arising from the data processing carried out. This is especially true given that after the implementation of these measures—with a significant investment in the appellant's view—the personal data breach for which the sanction is imposed occurred.

Therefore, this allegation must be dismissed.

Regarding the alleged non-compliance with Article 5.1(f) of the GDPR, let us begin by indicating the response provided in this regard on pages 71-72 (response to the allegations regarding the initiation agreement) and 167-171 (response to the allegations regarding the proposed resolution) contained in the contested resolution.

The appellant now considers that the reflection in the issued resolution of the precedents pointed out by her is incomplete and that, in her opinion, they demonstrate a difference of criteria regarding the one applied to her (since previously, in similar situations in her view, the AEPD has resolved with the filing of the procedure); a circumstance that does not allow for an adequate assessment of the facts present in those procedures and that would allow for a comparison with the present case.

In response to this allegation, it should be recalled what has already been stated in the sanctioning resolution, in the following terms:

In this regard, it was already indicated to her that this Agency does not have a filing criterion in the case of cyberattacks, of any kind, nor, therefore, regarding those affected by ransomware, but rather that, in matters of data protection, the technical and organizational security measures to be adopted by the data controllers and other obligations to be fulfilled required by the GDPR must be adequate in relation to the specific risks posed by the specific processing carried out by each controller. Therefore, when analyzing the diligence of each party in complying with the regulations, the circumstances of each case must be taken into account, considering the nature, scope, context, and purposes of each processing, with no identical cases existing. Thus, an attack carried out with the same ransomware at the same time and in different companies would yield disparate results, as the circumstances are different.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

25/48

this same attack against the same company at different times could determine a different situation.

Therefore, no matter how much the appellant insists on pointing out precedents from the years 2019, 2020, and 2021, whose facts, in their opinion, are similar, differing from the response of the AEPD, this supposed exercise of comparison cannot be applied because, as we already pointed out, there are no identical cases; rather, on the contrary, one must consider the specific circumstances present in each of them.

In addition to the above, it should be noted that the alleged coincidence regarding the facts subject to analysis in the precedents mentioned is based on a view that is, indeed, incomplete regarding the circumstances that occurred in them because, as we already stated in the contested resolution. On the other hand, in the majority of the Resolutions, everything related to specific security measures that are confidential in order to protect the security of the entities is omitted in their publication on the Agency's website, making it impossible to highlight the circumstances taken into account related to specific

information security measures.

That is to say, it is the AEPD that has all the elements of judgment to assess the circumstances present in the procedures that the appellant insists on pointing out and to conclude that they differ from those present in the sanctioning procedure in which it has been involved. Therefore, there has not been a difference in treatment that has harmed the appellant but rather a response from this Control Authority that takes into account the special characteristics and circumstances of each of the analyzed procedures.

In short, as we already indicated:

In several of these cases, there is no record of a breach of confidentiality, with the incident being limited to transient encryption or having recovered 100% of the data due to backups; there were appropriate technical and organizational measures; they had recently been subject to audits (many of them certification audits in accordance with ISO 27001 without obtaining any non-conformity; the number of affected individuals is different, etc. In short, there are no two identical cases even in the face of a similar attack because the companies are different, they have their own and different security measures at the time of the attack, the effects for the interested parties are different, etc.

From all the above, it is concluded that there are no two identical files, that in them, the preliminary investigative actions carried out by the AEPD revealed that there was no evidence of infringement for the specific case, that they had adequate measures, that no information was exfiltrated or accessed by third parties, that only availability was affected but that data could be recovered thanks to the existence of backups, etc.

Therefore, they are not susceptible to comparison with the circumstances of the present case, as they are very different organizations, either by their size (many of them SMEs), by the treatments they carry out, the

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

26/48

the typology of the same, the personal data involved, the existing risks, the affected systems, and the technological moment in which each cyber incident operates; in fact, not even the malware used is the same nor have the same attack methods been employed, the number of people affected, the measures implemented prior to the incident, etc.

Finally, none of them can be compared to the number of individuals affected by the personal data breach suffered by TPHS, which affected 13 million people.

For the reasons stated, there is no established criterion in this Agency for filing, nor for specific amounts of sanctions to be imposed in such cases, nor for specific infringements to be attributed in the case of cyberattacks, whether they are ransomware or of another type, since even in cases of ransomware, as noted, special attention is given to the modus operandi of the attack and the other specific circumstances, particularly and especially, the existing prior security measures.

To demonstrate the lack of consistency in the allegations contained in the appeal for reconsideration, it is sufficient to point out that the appellant states that (...) given that in none of the aforementioned procedures does this Agency even assess the potential non-compliance with Article 5.1 f) of the GDPR. In this regard, it should be noted that non-compliance with Article 5.1 f) cannot be "potential" but is reflected in an actual loss of confidentiality of the data, materializing in the fact that the data is known to third parties without justification. Likewise, a possible non-compliance with this provision cannot be assessed if, as we pointed out in the resolution, it was established in several of those precedents that no information was exfiltrated or that there was no access by third parties, that only availability was affected but that the data could be recovered thanks to the existence of backup copies, etc.

On the contrary, and as reasoned in the contested resolution (page 75)

Therefore, in the examined case, as stated in the proven facts, there is a clear loss of confidentiality since there has been access by an unauthorized third party to the personal data processed by TPHS, which is an objective result, acknowledged by TPHS, that does not imply objective liability. Thus,

adequate security has not been ensured through the application of appropriate technical and organizational measures, not only of security but of all types.

Regarding the positive assessment of detection and breach management procedures that the appellant understands was carried out in the aforementioned precedents, in addition to reiterating that the criterion of this AEPD is shaped according to the concurrent circumstances in each case, it must be recalled that the notification of a personal data breach is an obligation of the data controller as set out in Article 33 of the GDPR and, logically, this obligation could only be fulfilled with an adequate breach detection and management procedure.

It should also be remembered that non-compliance with this obligation constitutes an infringement according to the provisions of Article 83.4 a) of the GDPR.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

27/48

Therefore, this allegation must be dismissed.

The appellant subsequently raises allegations regarding the supposed non-compliance with Article 32 of the GDPR, with arguments that have already been extensively analyzed—and rebutted—in pages 75 to 90 and 171 to 193 of the contested resolution.

As can be observed, in the appeal, the appellant again questions the assessment made by this AEPD of the content of the "Clarifying Annex to the Incident Analysis Report on Ransomware," a matter that was already raised—and addressed—during the processing of the procedure.

Let us begin by recalling that, as already indicated to the appellant, first of all, this Agency has not solely relied on what was stated in the SIA Report, but has also taken into account all the documentation provided and gathered during the prior investigative actions, in which numerous deficiencies or lack of measures have been revealed, reflecting a clear infringement of Article 32 of the GDPR (...). That is to say, it is not that this Authority arbitrarily decided which documentation to assess and take into account, but rather that an analysis of all the documentation contained in the file was conducted. Again, the appellant seems to want to stage a kind of lack of rigor in the work performed by this Agency when, in fact, what has occurred is a rejection—properly substantiated at all times—of the allegations put forth. There has not been, although the appellant insists on raising it, a "free interpretation" by the AEPD, but rather a rigorous assessment, in accordance with technical and legal criteria, of the events that occurred, the implications for the right to personal data protection, and the legal response that our legal system provides in the face of such events.

The appellant insists on considering that the conclusions of the so-called SIA Clarifying Report do indeed rebut the conclusions reached by the AEPD, and to this end, refers to the technical criterion of the only IT expert who has had the opportunity to analyze the evidence and the digital environment in which it was obtained, and whose professional background allows him to opine in a qualified manner on the adequacy of the security measures adopted, possessing the "scientific, artistic, technical, or practical knowledge" necessary to issue an opinion. The appellant forgets that it is the AEPD that not only has had complete knowledge of the circumstances that occurred—not only through the documentation provided during the processing but also through the investigative actions carried out—but also that it consolidates the technical and legal knowledge, not only theoretical but practical, to appropriately assess those circumstances and conclude—and substantiate—what legal consideration they should have.

We cannot share the argument put forth that points of improvement or weaknesses in the security of a system cannot be equated, as the AEPD does, to an inadequacy of measures; on the contrary, those weaknesses are precisely what are avoided with the adoption and implementation of adequate measures in light of the risk derived from the processing of data carried out. The existence of a weakness—and more so if it is confirmed—is an open door to a situation of data security breach.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

The appellant insists once again on mentioning the four aspects where deficiencies were detected: implementation of measures related to Data Protection Impact Assessments (DPIAs), the implemented password policy, perimeter security, and user training. It is noteworthy that the appellant does not provide any new argument and that all the issues raised have already been addressed in the sanctioning resolution in the following terms:

- Implementation of measures related to DPIAs: pages 178 to 185

The appellant insists on questioning the extension of the recommended measures in the DPIAs conducted concerning high-risk processing to other distinct processing activities that are differentiated in the Register of Processing Activities; even if they share the characteristic of being a mass data processing. This is, as with the previous arguments analyzed in this resolution, a repeatedly raised and equally repeatedly answered argument:

Secondly, TPHS points out that the “digital marketing” and “access control to facilities” processing activities have nothing to do with the data affected by the breach suffered. It insists again that the processing related to the provided DPIAs has not been affected by the security breach, so there can be no causality between such processing and the security breach, which it understands to be the sole and exclusive reason for which the sanctioning procedure has been initiated against it.

Furthermore, TPHS indicates that the Agency has the register of activities and the PIAs because it was requested without specifying that it wished to receive the register of activities of the processing affected by the security breach or the DPIAs of the processing involved in the cyberattack, therefore, in the interest of maximum transparency, all the information contained in the register of processing activities was provided.

In this regard, it is appropriate to reiterate everything argued concerning this issue in Section Two of this Legal Basis, to which we refer, both in relation to the fact that regardless of the personal data breach suffered, TPHS had not implemented the security measures that it had indicated in its DPIAs two years prior to the incident, which in itself indicates that appropriate measures had not been applied to ensure adequate security to the risk, which in its case includes, among others: a) the pseudonymization and encryption of personal data, which constitutes a breach of Article 32 GDPR, as well as the fact that risk analyses and, where applicable, the DPIAs regarding the processing affected by the breach were specifically required, and it was TPHS that indicated, in response to the information requests made during the preliminary investigation proceedings, that among the processing activities affected by the personal data breach, “digital marketing” and “access control to facilities” are included. Therefore, those processing activities for which the DPIAs provided by TPHS were conducted were indeed affected by the breach, as indicated in the responses to the requests made, which it now simply contradicts.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

With these allegations, once again in the appeal phase, the appellant merely reaffirms the conclusion we reached: that the appellant contradicts what was stated during the processing of the sanctioning procedure with the sole intention of raising doubts about this Agency's assessment regarding the contested infringement.

The appellant again expresses her disagreement with the questioning of the approach of the DPIAs that was carried out during the processing of the file, despite the fact that, as she herself acknowledges, this issue is not the subject of the imposed sanction. We can only reiterate the response given on page 181 of the resolution where, after stating

In this regard, and as a prior and fundamental matter, it is noted that in the present sanctioning procedure, TPHS has not been charged with an infringement of Article 35 GDPR for failing to comply with the requirements demanded by the GDPR in the DPIAs, but it has only been pointed out that the approach is not correct. Therefore, it is not an essential issue in this sanctioning procedure nor does it

undermine the proven facts on which the alleged infringements are based.

Furthermore, as this interpretation has not been justified, it is appropriate to refer to the arguments made in the Proposal for Resolution regarding this same allegation, which is transcribed in the Ninth Background Fact, Sixth Allegation, where the reasons for indicating that the approach is not correct in most of the risks indicated in the submitted DPIAs have been clearly explained.

The following four pages provide a detailed explanation of why the approach applied in the DPIAs is considered incorrect.

- Password Policy: pages 185 to 188

The appellant again attempts to assert the conclusions reached in the Clarifying Report SIA, seeking to grant it, once again, a prevailing value even over the facts reflected in the report it seeks to clarify. In this regard, it has already been pointed out that

In this sense, these facts or findings have not been denied or distorted, but rather an assessment of them has been made, against which this Agency does not agree, as they reflect significant deficiencies regarding the password policy.

To then state that

Furthermore, Annex SIA only interprets or assesses the findings in the analysis of the incident that were reflected in the SIA Report. However, as previously indicated, when determining the existence of deficiencies in the password policy in the present sanctioning procedure, not only the content of the SIA Report has been taken into account but also

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

30/48

also the evaluation reports provided by the company Écija (Report “Evaluation of Compliance in Data Protection – Security Measures –”, dated January 11, 2021; Report “Evaluation of Compliance in Data Protection – Security Measures –”, dated January 11, 2021; as well as the inventory of systems provided by TPHS on June 28, 2021 (Registration Number: O00007128e2100028705). Finally, the measures that TPHS declared to have implemented or are in the process of being implemented after the breach have also been taken into account.

In this documentation, numerous and significant deficiencies were reflected - as detailed at the beginning of this Fourth section of the response to the allegations, to which reference should be made - which have not been disproven and reflect inadequate measures on the part of TPHS that do not appear in the SIA Report.

All of this demonstrates that, regardless of the detected personal data breach, the password policy and other restrictions for access to TPHS's information systems were not adequate to ensure appropriate security, posing vulnerabilities that could be exploited by any attacker. It should not be forgotten, as noted, that the SIA report indicates that it (...).

It follows that the assessment indicated now in the SIA Annex regarding that “the most common scenario in these cases is that a social engineering attack allowed obtaining such credentials by deceiving a user with administrative permissions,” that is, it could have been a phishing attack, but it could also have been through the other three possible entry vectors indicated in the SIA Report, all of which point to deficiencies in the password policy.

Regarding the allegation concerning the use of the MD5 algorithm, which the report refers to as not being “fully secure,” it states that this is a quality that cannot be claimed for almost any encryption mechanism, although this does not imply that it is commonly vulnerable (...)

In response to this, we can only refer to what is indicated in the contested resolution:

In this regard, it should be noted that the deficiency of the encryption algorithm is a true deficiency, an algorithm that is not secure at all and this was made evident years ago by the CCN, although it was included as a recommendation in the aforementioned report. What the report reflects is that TPHS was using that algorithm and that it is deficient, which has been known for years. It should not be forgotten that the attacker obtained the credentials of several TPHS users.

In short, the appellant has known for some time that the algorithm being used was deficient and,

despite this, was not diligent enough to use another. Considering that the attack that led to the personal data breach was motivated by access to the credentials of several users of the

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

31/48

In relation to the appellant, this lack of diligence had a direct and objective consequence on the causes of the breach and, therefore, on its consequences.

Finally, it should be noted, regarding the password policy, that the sanctioning resolution expressly states that

It should also be recalled that there was no other known and affordable measure according to costs and the current state of technology, such as two-factor authentication, which was not implemented at the time of the incident, not even for users with an administrator profile, as TPHS explicitly stated that it was "in the process of implementation."

-

Perimeter Security 188 to 192

The appellant insists on the quality of the measures adopted and that those implemented after the cyberattack are well above the recommended measures for a scenario with similar risks and go beyond the required diligence. In this regard, it is only necessary to mention something that is obvious but seems not to be considered as such by the appellant: the sanctioning file initiated, against which the appeal for reconsideration is filed, takes into account the measures in place at the time of the attack, which facilitated it and, consequently, the personal data breach for which the sanction is imposed.

In this sense, and in response to the measures that the appellant claimed to have adopted or indicates are "in the process of implementation" after the incident and that, therefore, were not implemented, the following was responded:

However, TPHS did not have them implemented. This would have allowed the possibility of detecting the malicious behavior of the attacker for 11 days (entries and exits by the cybercriminal from IPs located in countries such as Bulgaria and Moldova or from TOR nodes, their movements across the network, information leakage, etc.). Certainly, without them, there was no option for that.

It again questions the conclusions reached in the specialized report (SIA Report) provided by the appellant, attempting to disqualify its findings by stating that they correspond to a manipulated environment and that many of the deficiencies found in perimeter security may stem from alterations made by the intruder user (...). The appellant seems to forget that, precisely, the intruder had the capacity to infiltrate their systems due to the deficient security measures implemented, and this is without prejudice to the fact that no evidence or proof is provided that allows reaching the conclusion stated.

-

On User Training: 192

The appellant qualifies as a patent error in the assessment of the evidence carried out by the AEPD what is simply an assessment that it does not share and from which a clear non-compliance with the applicable regulations is derived. To attempt to attribute a lack of rigor to the fact that the allegations made have not been accepted is not acceptable.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

32/48

Once again, it makes considerations regarding the measures adopted in relation to the training of its employees, which, using the exact same terms as in its allegations to the proposed resolution, it qualifies as a robust, comprehensive, and ongoing plan for continuous training in data protection and information security.

On this point, we can only refer back to what was stated in the contested resolution:

Regarding what TPHS alleged concerning training, since this is a reiteration of what was stated in response to the Initiation Agreement, it is appropriate to refer to the response given in the Proposed Resolution, which is transcribed in the Ninth Background of Facts, Allegation Ninth. Likewise, it is appropriate to refer to what is indicated in the response to Allegation First of this Legal Basis. There, the response was provided by analyzing the documentation submitted by TPHS regarding training. Thus, it was indicated that “upon analyzing the documentation, it should be noted that most reflect generic courses and do not certify how many students participated or when they were conducted (document 4); a generic course without certifying who completed it and is not mandatory (screenshot of an email sent on November 17, 2019); a course directed at TPHS, regarding its obligations as a data controller (document 6); generic online courses to be completed by new employees hired from 2018, accompanied by a list of about 330 people who have completed it, without dates or signatures.” The appellant makes another series of allegations under the heading “Other measures” in which it refers to the AEPD’s questioning of the validity of the annual report of the Data Protection Officer (DPO) due to its date of issuance (referring to the year 2021 but adopted at the end of the same, in January 2022) and that it does not provide evidence—which would not be possible as it is not an audit. It should be noted in this regard that it was the appellant itself that submitted the report of its DPO in the procedure and, therefore, attempted to endow it with a kind of evidentiary nature that, however, it now seems to diminish to justify the absence of evidence.

Page 109: TPHS states that it had implemented, prior to the security breach, all recommendations derived from the “Technical Evaluation Report,” as well as from the “Legal-Organizational Evaluation Report” issued by an external entity, as evidenced by the various pieces of evidence provided by this party, as well as the content of the “2021 Annual Report of the Data Protection Officer,” submitted to this AEPD (see pages 1544 and 1545 of the Administrative File):

Page 137: Additionally, TPHS is interested in bringing up at this point the “Clarifying Annex to the Ransomware Incident Analysis Report,” as well as the “2021 Annual Report of the Data Protection Officer” (see pages 1542 to 1552 of the Administrative File), in order to demonstrate that TPHS had appropriate technical and organizational measures for

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
33/48

to guarantee an adequate level of security relative to the risk at the time it suffered the cyberattack.

On the other hand, it is not questioned that a report referring to the year 2021 was prepared subsequently, in this case, in January 2022, but it is indeed questioned that, being much later than the incident, it does not have the value intended by TPHS as evidence to reliably prove that those measures were implemented in the first quarter of the year, which, moreover, do not relate to those indicated.

Therefore, this allegation must be dismissed.

Regarding the allegations related to the existence of a competition of infractions that the appellant claims, we again find ourselves faced with a reiteration of arguments that have already been presented and duly rebutted.

As was pointed out in the contested resolution (allegations to the initiation agreement, pages 96-97) Well, Article 5.1.f) of the GDPR includes the principle of integrity and confidentiality and determines that personal data shall be processed in such a way as to ensure an adequate level of security of personal data, including protection against unauthorized or unlawful processing and against accidental loss, destruction, or damage, through the application of appropriate technical or organizational measures of all kinds, not only security measures.

Furthermore, Article 32 of the GDPR regulates how the security of processing should be articulated in relation to the specific security measures that must be implemented, in such a way that, taking into account the state of the art, the costs of implementation, and the nature, scope, context, and purposes of the processing, as well as the variable probability and severity risks to the rights and freedoms of

natural persons, the controller and the processor shall apply appropriate technical and organizational measures to ensure a level of security appropriate to the risk, which includes, among other issues, the ability to ensure the confidentiality of the data.

As noted, this provision, Article 32 of the GDPR, although related to Article 5.1.f) of the GDPR, does not encompass the principle in its entirety. Article 5.1.f) of the GDPR explicitly requires that confidentiality be guaranteed and requires a loss of confidentiality for its application. We may encounter situations where there are inadequate measures without there being a loss of integrity and confidentiality. (...) TPHS indicates that the appropriate technical and organizational measures referred to in Article 5.1.f) are the security measures of Article 32 of the GDPR. This would simplify the essence of the GDPR, whose compliance is not limited to the implementation of technical and organizational security measures; it would mean, in our case, reducing the guarantee required by the principle of integrity and confidentiality to its achievement solely through security measures. (...)

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

34/48

For the reasons stated, in the present case, the absence of specific security measures aimed specifically at ensuring confidentiality, namely encryption and pseudonymization (or anonymization), is what has resulted in the existence of the breach of confidentiality of personal data. If the data had been encrypted, anonymized, or pseudonymized, the criminals would have only taken unintelligible information. Hence, TPHS is charged with the infringement of Article 5.1(f), as it requires ensuring confidentiality through various measures, which can be both security-related and of another type.

However, the infringement of Article 32 of the GDPR that has been attributed to it is due to the lack or inadequacy of numerous measures, this time indeed aimed at ensuring an adequate level of security relative to the risk of the processing being carried out. Of all the security measures that are identified as missing or inadequate and that constitute a violation of Article 32 of the GDPR—those which are indicated in Legal Basis VII of this Proposal, to which we refer—there are only two that have proven decisive for the loss of confidentiality: again, encryption and pseudonymization or anonymization.

Therefore, in the present case, the aforementioned Article 32 has been infringed regardless of whether a breach of confidentiality has ultimately occurred or not, because the reproachable conduct that violates this provision is the lack or inadequacy of those measures in themselves, that is, it is infringed and sanctioned regardless of whether a breach of personal data has occurred or not. (...)

In this regard, it is noted that, concerning the citation of the Guidelines 04/2022 of the EDPB on the calculation of administrative fines under the GDPR, in its version 2.1, adopted on May 24, 2023, in its section 22, reference is made to three types of concurrence, namely, of infringement, unity of action, and plurality of actions: “When examining the analysis of the traditions of the Member States regarding concurrency rules, as indicated in the jurisprudence of the CJEU, and taking into account the different areas of application and legal consequences, these principles can be grouped approximately into the following three categories: - Concurrence of infringements (chapter 3.1.1), - Unity of action (chapter 3.1.2), - Plurality of actions (chapter 3.2).

In cases of concurrence of infringements, the provision established in this regard is contained in Article 83.3 of the GDPR, which establishes a quantitative limit in these cases of concurrence: “If a controller or a processor intentionally or negligently infringes various provisions of this Regulation for the same processing operations or linked operations, the total amount of the administrative fine shall not exceed the amount provided for the most serious infringements.” (the underlining is ours). (...)

Finally, and no less importantly, the AEPD does not sanction for the same offense, as the responding party claims, but rather it has been established through

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

35/48

of proven facts not rebutted by TPHS, the commission of two differentiated infractions, typified in a differentiated manner, not existing, moreover, in the specific case, a medial concurrence.

We are therefore faced with two perfectly differentiated infractions, which correspond to independently considered infringing types and, ultimately, it cannot be stated that we are dealing with a concurrence of infractions.

The appellant also alleges a contradiction between what this AEPD has stated regarding the fact that Article 83.3 applies to the concurrence of infractions and that, therefore, it would not be applicable to the case at hand in which, as we have been arguing, such concurrence of infractions has not occurred, and what the CEPD indicates in its Guidelines 4/2022.

In this regard, it is worth recalling that Article 83.3 states the following:

3. If a controller or a processor intentionally or negligently infringes various provisions of this Regulation for the same processing operations or related operations, the total amount of the administrative fine shall not exceed the amount provided for the most serious infringements.

The very wording of the provision, by setting the maximum limit as the amount provided for the most serious infringements, starts from the premise that the infringements are linked, as must be the sanctions that accompany them, in the sense that the maximum to be imposed will be that provided for the most serious of them. That is to say, by establishing this linkage between the sanctions—in the form of a limitation of the maximum amount—it must be concluded that the infringements must also be linked and that, therefore, one must necessitate the other, a situation that arises in cases of medial concurrence of infringements.

To reinforce this argument, it is worth highlighting the very jurisprudence of the Court of Justice of the European Union (CJEU), pointed out, not to mention, by the appellant in their appeal.

Thus, paragraph 72 of the CJEU judgment of December 5, 2023, issued in case C-683/21, states the following (the underlining is ours):

72. Furthermore, it is important to read Article 83, paragraph 2, of the GDPR in relation to paragraph 3 of that article, the purpose of which is to foresee the consequences of cases of accumulation of infringements of the Regulation and according to which "if a controller or a processor intentionally or negligently infringes various provisions of this Regulation for the same processing operations or related operations, the total amount of the administrative fine shall not exceed the amount provided for the most serious infringements."

In almost identical terms, paragraph 67 of the CJEU judgment of December 5, 2023, case C-807/21, pronounces.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

36/48

Therefore, this allegation must be dismissed.

Regarding the allegation concerning the inadmissibility of objective liability and as a demonstration that the appellant is once again raising arguments that have already been analyzed in the sanctioning resolution, it suffices to begin by stating that, as indicated in the same (page 199):

TPHS reiterates this allegation once again, which it already raised against the Initiation Agreement, the response to which was duly argued in the Proposal for Resolution and is transcribed in the Ninth Fact of the present Resolution, Fourth point, to which, in the interest of procedural economy, it is appropriate to refer. In that argumentation, the existence of negligence in TPHS's actions was already indicated. (...)

Thus, it was indicated that the breach of confidentiality attributed to TPHS is due to its failure to comply with the obligation imposed in Article 5.1.f to process the data in such a way as to ensure an adequate level of security, including protection against unauthorized or unlawful processing, through the application of appropriate technical or organizational measures.

It should not be forgotten, in this regard, that there are measures specifically aimed at ensuring the confidentiality of personal data, such as their encryption or the application of pseudonymization or

anonymization techniques, measures that TPHS expressly indicated in its DPIAs as necessary measures to be implemented to reduce the “high” or “very high” risks regarding the processing activities affected by the breach. However, as indicated in the Established Facts, at the time the security incident occurred, it resulted in a breach of personal data that affected their confidentiality because TPHS had not implemented those specific measures after more than two years of having detected those risks and indicated those measures in its DPIAs. Had they been applied, there would have been no access or exfiltration of personal data—nor publication of the same in clear text—as ultimately occurred, since the data would have been unintelligible to the perpetrator. This reflects, at the very least, a lack of due diligence on the part of TPHS.

Therefore, in the case examined, as stated in the established facts, there is a clear loss of confidentiality since there has been access by an unauthorized third party to the personal data processed by TPHS, which is an objective result, acknowledged by TPHS, that does not constitute objective liability. Thus, adequate security has not been ensured through the application of appropriate technical and organizational measures, not only of security but of all kinds.

In response to the allegation once again made that an objective liability is being imposed independent of the measures deployed, it is necessary to recall what we reasoned in the contested resolution (page 202):

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
37/48

As has been demonstrated and argued throughout this sanctioning procedure, it is considered that appropriate security measures were not implemented to ensure adequate security against the risk, even though there was no breach of personal data.

In this regard, this Agency wishes to point out that it does not consider that the obligation to implement security measures imposed by data protection regulations has a nature of an obligation of result rather than means. However, it is equally true that TPHS did not have, prior to the incident, measures that “according to the state of technology and in relation to the nature of the processing carried out and the personal data in question, reasonably allow for the prevention of their alteration, loss, processing, or unauthorized access.”

Unlike what the appellant claims, this assertion is not justified solely by the outcome, but rather, as repeatedly indicated, the absence of technical and organizational security measures has been established regardless of whether the loss of confidentiality resulting from the personal data breach occurred.

The appellant also points out that the CJEU has already concluded that the increase in obligations for the processing of personal data resulting from the entry into force of the GDPR should not be understood as the possibility for the regulations to include an extension of liability, particularly concerning the necessary requirements to attribute sanctioning consequences to the conduct of the legal entity.

It again refers to the jurisprudence of the CJEU that was already taken into account in the resolution subject to appeal in the following terms:

Finally, TPHS adds that this fact clearly demonstrates that the existence of a culpable, intentional, or negligent act on the part of TPHS is not established, and therefore, it cannot identify in its conduct a violation of personal data protection regulations merely by having been a victim of a cyberattack, and consequently, the imposition of any type of sanction is not appropriate, all taking into consideration the recent jurisprudence of the Court of Justice of the European Union (CJEU) related to cases C-683/21 (Nacionalinis visuomenės sveikatos centras) and C-807/21 (Deutsche Wohnen) published on December 5, 2023.

In contrast, the existence of deficiencies in the applied security measures has been established, as well as the absence of others, reflecting negligence on the part of TPHS, thereby incurring the alleged violations. This negligence is what the aforementioned ruling requires to impose sanctions for non-compliance with the obligations established by the GDPR on data controllers.

In this regard, it is important to highlight that the appellant starts from a mistaken premise: that, by not being considered culpable of the conduct attributed to it, the imposition of a sanction for the same implies a modification of the conditions.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

38/48

materials for establishing liability. This conclusion cannot be shared.

Thus, let us recall that the CJEU ruling in case C-683/21 states the following:

73 Therefore, from the wording of Article 83, paragraph 2, of the GDPR, it follows that only violations of the provisions of the Regulation committed with culpability by the data controller, namely those committed intentionally or negligently, can lead to the imposition of an administrative fine under that article.

80 Consequently, it must be declared that Article 83 of the GDPR does not allow for the imposition of an administrative fine for a violation covered in paragraphs 4 to 6 without demonstrating that such violation was committed intentionally or negligently by the data controller and that, therefore, culpability in the commission of the violation constitutes a requirement for the imposition of the fine.

In identical terms, the CJEU ruling in case C-807/21 states in paragraphs 68 and 75, respectively.

In short, these rulings are based on the premise that the culpability of the conduct attributed to the offender must constitute the premise for the imposition of the fine. A circumstance that, as we have been arguing, occurs in the factual situation at hand, where the conduct for which the sanction is imposed is culpable and arises from a clearly demonstrated lack of diligence.

For all the above reasons, this allegation must also be dismissed.

Regarding the allegation related to the 211 complaints related to the security breach, the appellant reproduces at this point, almost in its exact terms, the allegations made in the proposal for resolution (page 204 et seq.)

In this regard, it should be noted that TPHS requested a copy of the aforementioned complaints in July 2022, that is, while the preliminary investigation proceedings were being carried out. In both cases, they were not provided with the same as it was communicated to them by the General Sub-Directorate for Data Inspection that the preliminary investigation proceedings aim to achieve a better determination of the facts and circumstances that could justify, if applicable, the processing of a sanctioning procedure, and could not last longer than twelve months. It was also communicated to them that, once concluded, the result would be made known to the interested parties, notifying them of the filing of the preliminary investigation proceedings, or the agreement to initiate the procedure for the exercise of the sanctioning power.

Therefore, throughout the sanctioning procedure, TPHS has not expressly requested either access to or a copy of the aforementioned complaints. What TPHS has requested is a copy of the sanctioning file, which was duly provided to them and which does not include those complaints.

Notwithstanding the above, the fact that they were not included in the copy of the requested file - because they are not included therein - has not caused them any defenselessness since the present sanctioning procedure has been based on the proven facts obtained during the preliminary investigation proceedings carried out and that these have not focused on the complaints but on the investigations carried out following the notification of the personal data breach made by TPHS, that is, on the documents obtained in it, mainly provided by the company itself.

(...) in the present case, the investigative actions were not initiated or prompted as a result of the complaints filed, but were a consequence of the notification by TPHS of the personal data breach suffered. This is indicated in the internal note referred to in which the Director of this Agency directed the General Sub-Directorate for Data Inspection on April 19, 2021, ordering them to assess the need to carry out the appropriate preliminary investigations. And that is the date that is taken into account for the start of the computation of the investigative actions, which, after twelve months, were declared expired on April 19, 2022, and the initiation of new investigative actions.

Furthermore, the new investigative actions were opened in order to be able to continue with them,

specifically to be able to request clarification on some aspects as well as to gather evidence regarding various aspects (...)

It should be clarified on the other hand that the indication that these complainants will be informed of the existence of the final resolution concluding the sanctioning procedure does not mean that their complaints have been taken into account or that their lack of knowledge by the appellant has caused them defenselessness, as they insist on asserting, but rather stems from the provisions of the LPACAP

- In Article 4. Concept of interested party

1. Those who, without having initiated the procedure, have rights that may be affected by the decision adopted therein are considered interested parties in the administrative procedure. (...)

- In Article 40. Notification.

1. The body that issues the resolutions and administrative acts shall notify them to the interested parties whose rights and interests are affected by them, in the terms provided in the following articles. (...)

This allegation must be dismissed.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

40/48

It contains below the appeal allegations related to the evidence, as the appellant qualifies the assessment of the evidence carried out by the AEPD as partial and differentiated. Again, it seems to confuse the difference in criteria regarding the necessity of carrying out certain evidence with a lack of rigor in its assessment.

It insists once again on the evidentiary value of the additional SIA report submitted; a document that, we reiterate, has been taken into consideration but which, contrary to what the appellant insists on proposing, cannot undermine the conclusions drawn from the rest of the documents and findings that make up the file and on the basis of which the sanctioning resolution has been issued. As has been indicated to it repeatedly, the so-called "clarifying SIA report" has been duly analyzed and assessed, an analysis and assessment that has not allowed for conclusions that undermine the fact that the infringing behaviors that are sanctioned have been committed.

In short, this allegation is dismissed.

Regarding the absence of proportionality in the determination of the amount of the imposed sanction, we can only refer again to what has already been reasoned in the contested resolution:

Page 208

Firstly, and contrary to TPHS's interpretation of the limits of the amounts of the fines, it has already been explained and argued how the RGPD establishes these limits in the response given to this allegation in the Proposal for Resolution, which is transcribed in the Ninth Background of Fact, point Tenth, to which we must refer.

Thus, it was pointed out, firstly, that Article 83.1 RGPD establishes that administrative fines for infringements of the RGPD must be "...effective, proportionate, and dissuasive in each individual case," indicating subsequently in paragraph 2 of the cited provision that "Administrative fines shall be imposed based on the circumstances of each individual case, as an additional or substitute measure for the measures provided for..." (the underlining is ours). It then establishes certain circumstances to be taken into account.

(...)

Secondly, regarding the maximum limit, TPHS is charged with two infringements: one for violating Article 5.1.f) RGPD and another for violating Article 32 RGPD, infringements which are classified in Article 83.5 and 83.4 respectively.

In this regard, Article 83.5 RGPD states that the infringements of the provisions it indicates "...shall be sanctioned with administrative fines of up to 20,000,000 EUR, or, in the case of a company, an amount equivalent to a maximum of 4% of the total annual global turnover of the previous financial year, opting for the higher amount" (the underlining is ours).

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
41/48

Furthermore, Article 83.4 states that violations of the provisions it indicates “...shall be sanctioned with administrative fines of up to 10,000,000 EUR, or, in the case of a company, an amount equivalent to a maximum of 2% of the total annual global turnover of the previous financial year, opting for the higher amount” (the underlining is ours).

That is to say, the percentages based on turnover, when it comes to a company, do not operate as maximum limits when the figure they yield is less than 10 or 20 million - depending on whether we are in the classification of section 4 or 5 of Article 83 GDPR respectively - but rather, quite the opposite, they allow for a maximum limit higher than those 10 or 20 million.

Therefore, when the 2% or 4% of the total annual global turnover of the fine imposed for each violation is less than the maximum amounts established in the aforementioned provisions, 10 or 20 million euros, the latter will be the maximum limits. Conversely, if those percentages yield higher amounts, they will be considered as the maximum limits. This is because the GDPR establishes that the higher amount must be chosen. (...)

In this case, the circumstances of the case have been taken into account: the severity of the violations, the consequences thereof, the lack of diligence shown, the specific processing carried out, the type of personal data and the number of affected individuals, the circumstances of the company (size, turnover, etc.), all of which are highlighted and motivated in the Initiation Agreement of this sanctioning procedure and are reproduced in the Legal Grounds VI and IX of this Resolution, to which we refer, which allow us to conclude that the principle of proportionality has been respected when determining the amount of the fines ultimately imposed.

Therefore, when determining the amount of the fines, not only the level of business of the companies is taken into account. This is just one more circumstance. Other circumstances are also considered, as noted, especially the specific circumstances of each case (what has happened, the effects or repercussions for personal data, number of affected individuals, level of negligence, etc.). In the file that brings TPHS to mind, the circumstances are very different and, by way of example, in the aforementioned EXP202204846, the breach of confidentiality of the personal data of 760 individuals was confirmed and potentially millions (but not substantiated). Whereas in the case at hand, it is substantiated that the confidentiality of the personal data of 13 million individuals has been breached, constituting, from the perspective of the number of affected individuals, one of the most significant episodes of personal data exfiltration, if not the most significant, that has occurred in our country. We again bring to mind what was stated by the CJEU in the judgment delivered in case C-683-21.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
42/48

78 The existence of a sanctions system that allows for the imposition of an administrative fine in accordance with Article 83 of the GDPR, when the specific circumstances of each case justify it, creates an incentive for data controllers and processors to comply with the Regulation. With its deterrent effect, administrative fines contribute to strengthening the protection of individuals regarding the processing of personal data and thus constitute a key element in ensuring respect for the rights of such individuals, in accordance with the purpose of the aforementioned Regulation to ensure a high level of protection for those individuals concerning the processing of personal data.

In the same vein, paragraph 73 of the CJEU ruling in case C-807/21 also questions the appellant regarding the number of affected individuals reflected in the resolution and claims that the figure of 13 million corresponds to its users and clients, but it is not evidenced in any way that this is the number of individuals whose data has been affected. This assessment cannot be shared as it has been established in the file that it was the appellant itself that identified this figure as the number of affected

individuals.

(Page 91)

Regarding the number of affected individuals, it cannot be overlooked that it is extremely high: 13,000,000 affected individuals. This is a figure that leaves no room for doubt. In this regard, concerning what TPHS has argued about this Agency making a subjective assessment of the volume of affected individuals and that its number is merely an unverified approximation or estimate, it should be noted that it was the company itself that, when notifying this Agency of the personal data breach, in its submission dated April 28, 2021 (registration no. O00007128e2100019496), indicated in the section "Approximate number of affected personal data records: 13,000,000."

Attached to that notification, TPHS provided the document "Security Breach Assessment Report," in which page 18 states "Approximate number of affected individuals: 13,000,000."

Furthermore, in the "Ransomware Incident Analysis Report" prepared by SIA Group, contracted by TPHS to analyze the incident and dated April 21, 2021, and submitted by the same to the file, it is indicated in the "Conclusions" that, regarding the publications made by the cybercriminal, it states that "Finally, on Tuesday, April 20, 2021, it publishes on another domain of the TOR network two files of around 1 GB in size containing personal data of 13 million individuals."

Therefore, it cannot be accepted that it is a subjective assessment of this Agency without any basis to consider that a very high number of individuals were affected (the figure of 13 million alone is sufficient for such consideration), nor that the number of affected individuals is unverified, as it has been indicated by the company itself, in addition to being stated in the report prepared by the cybersecurity expert company contracted by TPHS precisely to analyze the incident that occurred.

Thus, it cannot be questioned the veracity of a data point that was provided by the appellant itself and that, as such, was reflected in the resolution being appealed.

We conclude, therefore, that the imposed sanction is proportional to the infringement committed and its consequences, in accordance with the spirit and objective criteria established by the GDPR, (...).

For the reasons stated above, this allegation is dismissed.

Regarding the allegation concerning the aggravating factors associated by the AEPD to the infringements, the appellant questions the circumstances that have been taken into account as aggravating factors, expressing its disagreement, with arguments again coinciding with those already raised during the sanctioning procedure:

1) Nature and severity of the infringement (Article 83.2 a) GDPR). The appellant understands that the number of individuals affected by the breach has not been confirmed and is not specified in the resolution. In this regard, we refer to what was previously indicated that the figure of 13 million individuals comes from the information precisely provided by the appellant.

2) Regarding the level of damages and losses suffered, it understands that there is no evidence that the data affected by the breach has been published on the Deep Web.

In this regard, we refer to what is stated in the resolution, on page 5.

On April 28, 2021, TPHS submitted a new notification (hereinafter Notification 2) expanding the information about the security breach notified on the 14th of the same month, in which they indicate that, (...).

As well as on page 12.

In Report 28A, the investigated party states that, from the investigations carried out, the following impacts of the attack have been concluded:

(...).

Or on page 38.

It concludes, therefore, that, regarding confidentiality, it must be taken into account that once it has been violated by an attack that produces a security breach, the subsequent unlawful action.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

44/48

by cybercriminals, consisting of the publication of information on the Deep Web, is an independent fact

and not attributable to the Company, as it has no capacity to prevent it. Therefore, it can be stated that the publication of the data on the Deep Web has been established.

It is also worth recalling what is stated on page 212 of the contested resolution in the following sense: Thus, the publication of personal data on the Deep Web is not attributed to it, but it is mentioned as a factor establishing that confidentiality was breached and that the data appeared in clear text. The breach of confidentiality attributed to TPHS is the one that corresponds to it, that is, for failing to comply with the obligation imposed in Article 5.1.f to process the data in such a way as to ensure an adequate level of security, including protection against unauthorized or unlawful processing, through the application of appropriate technical or organizational measures.

It should be noted, in this regard, that there are measures specifically aimed at ensuring the confidentiality of personal data, such as their encryption or the application of pseudonymization or anonymization techniques, measures that were also expressly indicated in its DPIAs regarding the processing activities affected by the breach. Had these measures been applied, unauthorized third-party access to personal data would not have occurred, nor consequently the subsequent publication of the same. This is because the loss of confidentiality was confirmed as a consequence of the exfiltration of the data; loss of confidentiality, access by a third party to personal data, which would not have occurred if these had been encrypted or pseudonymized or anonymized, as the criminals would have taken unintelligible information.

In this respect, it is appropriate to again bring to mind the Judgment of June 22, 2021 - Rec. 1210/2018, and the Judgment of November 5, 2011 - Rec. 1796/2019 in which the Chamber, evaluating the subjective or culpability element, "...insisting that the culpability of the plaintiff cannot be considered excluded or mitigated by the fact that there has been possible fraudulent action by a third party, since the responsibility of the plaintiff does not derive from the action of this third party, but from its own."

3) Duration of the infringement

The appellant bases its allegations regarding this circumstance on the reiterated argument that the information systems identified in the DPIAs whose measures were not adopted, a fact that is taken into account for the grading of the sanction, are not related to the breach suffered. In this regard, and for procedural economy, we refer to the arguments previously mentioned.

4) Intent or negligence in the infringement

As has been clearly demonstrated throughout the processing of the entire sanctioning procedure, the culpable conduct attributable to the appellant has been established, whose legal response is contained in the contested resolution. It is worth recalling what we stated on page 213.

Regarding the alleged lack of negligence, it is noted that the consideration of its existence has been perfectly argued throughout the sanctioning procedure, both in the Initiation Agreement and in the Proposal for Resolution, as the absence of certain measures, as well as deficiencies in others, reflects a clear lack of the duty of diligence that must be required of a company with the nature of data processing it carries out, as well as due to the massive nature of these.

And this is without accepting that the condition of victim or harmed by the cyberattack allows evading its responsibility for the lack of measures that could have at least mitigated the consequences of the personal data breach.

5) Linkage of the infringer's activity with the processing of personal data

The appellant argues that its activity cannot be considered, in a generic manner, as an aggravating factor and points out that the aforementioned Guidelines 4/2022 exclude the specific activity and business sector of the infringer as a criterion to be considered in the imposition and quantification of sanctions for the infringement of data protection regulations.

The appellant seems to overlook the fact that the circumstance taken into consideration is not the activity it performs in itself, but the clear fact that, in its execution, it carries out massive processing of personal data. And it is evident that, being a company accustomed to processing personal data, its requirement for diligence must be greater.

In short, as argued in the contested resolution:

It should be noted that for the purposes of deciding the imposition of an administrative fine, the same consideration cannot be given to an infringement committed by a natural person or a small company

not accustomed to processing personal data, as to a large company like TPHS, accustomed to processing personal data of millions of clients and non-clients, with a long history in this regard. Of course, it is considered that the infringement is more serious.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
46/48

for the purpose of imposing a fine if the data controller is among the second group, as is the case with TPHS.

Based on the above reasoning, this allegation must also be dismissed.

The appellant then makes allegations regarding the presence of mitigating factors not considered. The appellant claims that it acted diligently, adopting the necessary measures to mitigate its effects and reinforce the security of its systems. It also points out that this mitigating factor was applied in the file referenced as EXP202204846.

In response to this, it should be reiterated that, in the present case, the circumstances of the case have been taken into account: the severity of the violations, the consequences thereof, the lack of diligence shown, the specific treatments carried out, the type of personal data, and the number of affected individuals, as well as the circumstances of the company (size, business volume, etc.).

As we reasoned in the sanctioning resolution (page 210),

therefore, when determining the amount of the fines, not only the business level of the companies is taken into account. This is just one more circumstance.

Other circumstances are also considered, as noted, especially the specific circumstances of each case (what has happened, the effects or repercussions for personal data, number of affected individuals, level of negligence, etc.). In the file brought up by TPHS, the circumstances are very different and, by way of example, in the aforementioned EXP202204846, the breach of confidentiality of personal data of 760 individuals was confirmed, and potentially millions (but not substantiated). Whereas in the case at hand, it is substantiated that the confidentiality of personal data of 13 million individuals has been breached, which constitutes, from the perspective of the number of affected individuals, one of the most significant episodes of personal data exfiltration, if not the most significant, that has occurred in our country.

Furthermore, the absence of adequate measures and the deficiencies detected in others have revealed significant negligence on the part of TPHS, with known, basic security measures that are accessible to a company of its size and with the massive treatments it carries out involving millions of individuals.

For all the above reasons, this allegation must also be dismissed.

Finally, the appellant makes a series of considerations regarding the measures imposed in the sanctioning resolution. It understands that its treatments were already compliant with the regulations at the time the events occurred and provides documentation related to the measures adopted (Document No. 2), the list of employees who received training in data protection in 2023 (Document No. 3), an explanatory video of the origin of the list (Document No. 4), and updates the number of employees of the company as of the date of the appeal. In this regard, it should only be noted that any consideration related to the measures indicated in the contested resolution must be made in accordance with what is stated therein; specifically in the third section of the dispositive part, which states the following:

THIRD: TO ORDER THE PHONE HOUSE SPAIN, S.L. with NIF B81846206, that pursuant to Article 58.2.d) of the GDPR, within six months, notify the Agency of the adoption of the measures in light of the content of the legal basis X.

III

Conclusion

Consequently, in the present appeal for reconsideration, the appellant has not provided new facts or legal arguments that would allow for a reconsideration of the validity of the contested resolution, so the allegations presented cannot be accepted and it must be concluded with the dismissal of the appeal submitted.

IV

Late Resolution

Due to reasons related to the functioning of the administrative body, therefore not attributable to the appellant, until the date of this document, the mandatory pronouncement of this Agency regarding the present appeal has not been issued.

In accordance with the provisions of Article 24 of Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations (LPACAP), the sense of administrative silence in the procedures for challenging acts and provisions is dismissive.

Nevertheless, and despite the time elapsed, the Administration is obliged to issue an express resolution and to notify it in all procedures, regardless of their form of initiation, as provided in Article 21.1 of the aforementioned LPACAP.

Therefore, it is appropriate to issue the resolution that concludes the procedure of the appeal for reconsideration filed.

Considering the cited provisions and others of general application, the Director of the Spanish Agency for Data Protection RESOLVES:

FIRST: TO DISMISS the appeal for reconsideration filed by THE PHONE HOUSE SPAIN, S.L. against the resolution of this Spanish Agency for Data Protection issued on December 27, 2023, in file EXP202306260.

SECOND: TO NOTIFY this resolution to THE PHONE HOUSE SPAIN, S.L.

THIRD: To warn the sanctioned party that the imposed sanction must be enforced once this resolution is notified, in accordance with the provisions of Article 98.1.b) of Law 39/2015, of October 1, on the Common Administrative Procedure.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

48/48

Common of the Public Administrations, within the voluntary payment period indicated in Article 68 of the General Collection Regulation, approved by Royal Decree 939/2005, of July 29, in relation to Article 62 of Law 58/2003, of December 17, by depositing it into the restricted account No. ES00 0000 0000 0000 0000 0000, opened in the name of the Spanish Agency for Data Protection at CAIXABANK, S.A., or otherwise, collection will proceed in the executive period.

If the date of notification falls between the 1st and the 15th of each month, both inclusive, the deadline for voluntary payment will be until the 20th of the following month or the next business day thereafter, and if it falls between the 16th and the last day of each month, both inclusive, the payment deadline will be until the 5th of the second following month or the next business day thereafter.

In accordance with the provisions of Article 50 of the LOPDGDD, this Resolution will be made public once it has been notified to the interested parties.

Against this resolution, which concludes the administrative procedure in accordance with Article 48.6 of the LOPDGDD, and in accordance with the provisions of Article 123 of Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations (LPACAP), the interested parties may file a contentious-administrative appeal before the Contentious-Administrative Chamber of the National Court, in accordance with the provisions of Article 25 and Section 5 of the fourth additional provision of Law 29/1998, of July 13, regulating the Contentious-Administrative Jurisdiction, within two months from the day following the notification of this act, as provided in Article 46.1 of the aforementioned Law.

Finally, it is noted that in accordance with the provisions of Article 90.3 a) LPACAP, the firm resolution in the administrative procedure may be provisionally suspended if the interested party expresses their intention to file a contentious-administrative appeal. If this is the case, the interested party must formally communicate this fact by means of a written document addressed to the Spanish Agency for Data Protection, submitting it through the Agency's Electronic Registry

[<https://sedeagpd.gob.es/sede-electronica-web/>], or through any of the other registries provided for in Article 16.4 of the aforementioned LPACAP. They must also provide the Agency with documentation

that proves the effective filing of the contentious-administrative appeal. If the Agency is not aware of the filing of the contentious-administrative appeal within two months from the day following the notification of this resolution, the provisional suspension would be considered terminated.

180-21112023

Mar España Martí

Director of the Spanish Agency for Data Protection

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es